End-to-End Test Report

Week 12 · Care Access Navigator · HealthLine Regional Medical Center (HRMC)

Test case catalog TC-01 to TC-10 (12-week plan, section 13) executed against the live lab

Author	Akhila Chennamaneni
Date	November 3, 2026
Version	v1.0
Run	2026-11-03T21:25:52Z to 2026-11-03T21:26:28Z (UTC); TC-05 retest 21:31Z
System	Keycloak realm care-access-navigator after Week 5 hardening; can_iam.py + e2e_tests.py
Evidence	06_Evidence/04_Test_Results/EV-14_End_to_End_Tests_20261103/ (results, audit log, access reviews, login events, detections; SHA-256 indexed)
Result	10 of 10 passed (TC-05 failed on the first run and passed after corrective action CA-10)

TC	Scenario	Expected result	Result
TC-01	New clinician receives approved role	Only clinician-approved application access is granted	**PASS**
TC-02	Billing user attempts clinical / admin function	Access denied	**PASS**
TC-03	Employee changes from Nurse to Billing	Old access removed; new billing access granted	**PASS**
TC-04	Employee termination simulated	Identity disabled and access revoked/removed	**PASS**
TC-05	Repeated failed authentication	SIEM detects/alerts based on configured threshold	**PASS (retest)**
TC-06	Disabled user attempts login	Event is visible and investigated	**PASS**
TC-07	Unexpected privileged-role assignment	Change is detected/reviewed and unauthorized privilege removed	**PASS**
TC-08	Vendor account reaches expiry	Access is disabled or flagged for review	**PASS**
TC-09	Quarterly access review identifies excess access	Finding becomes remediation task	**PASS**
TC-10	High-risk control gap identified	Risk is recorded, assigned and tracked	**PASS**

Test data: Test identities were created by the run itself: test.clinician3 (Priya Natarajan, joiner), test.nurse2 (Maya Rivera, joiner → mover → leaver) and test.vendor2 (Omar Haddad, vendor past end date). Passwords were random per run and never written to disk. test.nurse2 and test.vendor2 are left disabled and kept for audit. TC-07 used a simulated insider change on test.vendor1, reversed in the same run.

Test case details

TC-01 · New clinician receives approved role

Steps	1. can_iam.py joiner (REQ-2026-0601, group Clinicians) 2. first sign-in completed 3. sign in to all 4 apps
Actual	**groups**: Clinicians **roles**: clinician **logins**: **ehr-simulator**: LOGGED_IN (auth code issued) **patient-portal**: LOGGED_IN (auth code issued) **billing-app**: DENIED (role not approved for this app) **hr-app**: DENIED (role not approved for this app)
Evidence	can_iam_audit_log.jsonl: JOINER, E2E.login
Result	**PASS**

TC-02 · Billing user attempts clinical / admin function

Steps	1. sign in as test.billing2 to ehr-simulator, patient-portal, hr-app
Actual	**logins**: **ehr-simulator**: DENIED (role not approved for this app) **patient-portal**: DENIED (role not approved for this app) **hr-app**: DENIED (role not approved for this app)
Evidence	E2E.login; keycloak_login_events.csv (LOGIN_ERROR access_denied); CAN-ID-004
Result	**PASS**

TC-03 · Employee changes from Nurse to Billing

Steps	1. joiner nurse (REQ-2026-0602) 2. EHR sign-in before 3. can_iam.py mover (CHG-2026-0602) 4. EHR + Billing sign-in after
Actual	**before**: **snapshot**: **username**: test.nurse2 **enabled**: True **groups**: Nurses **effective_roles**: nurse **sessions**: 0 **ehr**: LOGGED_IN (auth code issued) **after**: **snapshot**: **username**: test.nurse2 **enabled**: True **groups**: Billing **effective_roles**: billing **sessions**: 0 **ehr**: DENIED (role not approved for this app) **billing**: MFA_REQUIRED (OTP setup/prompt shown)
Evidence	can_iam_audit_log.jsonl: MOVER removed/added
Result	**PASS**

TC-04 · Employee termination simulated

Steps	1. can_iam.py leaver (TERM-2026-0602) 2. old password tried on ehr-simulator
Actual	**after**: **username**: test.nurse2 **enabled**: False **groups**: none **effective_roles**: none **sessions**: 0 **login**: DENIED (account disabled)
Evidence	can_iam_audit_log.jsonl: LEAVER verification
Result	**PASS**

TC-05 · Repeated failed authentication

Steps	1. 11 wrong passwords for test.vendor1 2. can_iam.py detect
First run	**FAIL** — first run: TC-05 attempts fell inside the 10-minute window of the 21:20 W5 lockout test, and CAN-ID-001 raised only one alert per user for all history (defect, fixed as CA-10)
Corrective action	CA-10: CAN-ID-001 de-duplication defect fixed. Retest: fresh burst run after the 10-minute window of the earlier W5 test had closed.
Actual	**start_utc**: 2026-11-03T21:31:01.087974+00:00 **locked**: True **numFailures**: 10 **alerts**: CAN-ID-001 brute force (High) 21:31:01Z test.vendor1: 11 failed logins in 10 min
Evidence	identity_detections.csv CAN-ID-001; E2E.lockout
Result	**PASS (retest)**

TC-06 · Disabled user attempts login

Steps	1. terminated test.nurse2 signs in (TC-04) 2. can_iam.py detect
Actual	**alerts**: CAN-ID-002 disabled-account login (High) 21:26:10Z test.nurse2: client=ehr-simulator
Evidence	identity_detections.csv CAN-ID-002; keycloak_login_events.csv user_disabled
Result	**PASS**

TC-07 · Unexpected privileged-role assignment

Steps	1. insider adds test.vendor1 to Billing (no ticket) 2. access review 3. remove from Billing (CA-07) 4. can_iam.py detect

Actual	**alerts**: CAN-ID-005 privilege change (High) 21:26:10Z test.vendor1: CREATE groups: Billing (by admin event) CAN-ID-005 privilege change (Medium) 21:26:10Z test.vendor1: DELETE groups: Billing (by admin event) **review_flags**: MULTIPLE_ROLES_SOD_CHECK;VENDOR_NO_END_DATE;PRIVILEGED_NO_MFA_ENROLLED;STALE_NO_LOGIN_90D **after_roles**: vendor
Evidence	identity_detections.csv CAN-ID-005; access_review_AR-E2E-TC07-20261103.csv
Result	**PASS**

TC-08 · Vendor account reaches expiry

Steps	1. vendor joiner with access_end_date=2026-11-02 (REQ-2026-0603) 2. access review 3. leaver (TERM-2026-0603)
Actual	**review_flags**: ACCESS_PAST_END_DATE **risk**: High **after**: **username**: test.vendor2 **enabled**: False **groups**: none **effective_roles**: none **sessions**: 0
Evidence	access_review_AR-E2E-TC08-20261103.csv; LEAVER
Result	**PASS**

TC-09 · Quarterly access review identifies excess access

Steps	1. access review 2. flag DISABLED_BUT_HAS_ACCESS on Jeevan Smith (leaver) 3. corrective action CA-09: remove role 4. re-review
Actual	**before_flags**: DISABLED_BUT_HAS_ACCESS;PRIVILEGED_NO_MFA_ENROLLED **removed**: billing **after_flags**: none **after_roles**: none
Evidence	access_review_AR-E2E-TC09-BEFORE/AFTER-20261103.csv; E2E.remediation
Result	**PASS**

TC-10 · High-risk control gap identified

Steps	1. audit finding F-03 (no 12-month log retention, High) 2. risk R03 credential compromise / monitoring gap 3. exception EX-02 with compensating controls 4. corrective action CA-03 5. dashboard tile Open High findings
Actual	**trace**: F-03 -> R03 -> EX-02 -> CA-03 -> audit_findings.csv / exceptions.csv (Tableau)
Evidence	CAN_DOC_Exceptions_and_Corrective_Actions_v1.0.xlsx; Tableau_Dataset

Result	**PASS**

Findings from the test run

Finding	Found by	Action	Status
The brute-force rule CAN-ID-001 raised one alert per user for all history, so a second attack on the same account was never alerted	TC-05	CA-10: alert once per 10-minute burst; retested with a fresh burst	**Verified**
The approved leaver for Jeevan Smith (TERM-2026-0301) disabled the Keycloak copy but left the Entra-mapped billing role on it	TC-09 (access review)	CA-09: role removed. Federated leavers must go through can_iam.py leaver (strips IdP-mapped roles), not only Disable in the console	**Verified**
test.vendor1 has no sponsor or access end date	TC-07 review flags	CA-08: sponsor decision	Open
Privileged accounts not yet enrolled in OTP	Access reviews	CA-13: enrolment forced at next sign-in	In progress

Proof of detection and proof of prevention (identity layer)

Attack (simulated)	Prevention	Detection
Password guessing on test.vendor1	Locked after 10 failures (TC-05)	CAN-ID-001 High
Billing user opens the EHR (ePHI)	Denied by the EHR gate (TC-02)	CAN-ID-004 Medium
Terminated nurse signs in	Denied: account disabled (TC-04)	CAN-ID-002 High (TC-06)
Insider adds a vendor to Billing	Access review flag + removal (TC-07)	CAN-ID-005 High
Vendor past end date	Flagged High + leaver (TC-08)	ACCESS_PAST_END_DATE; CAN-ID-006 if used

Not covered by this run

- Entra-federated sign-in with Entra MFA (needs the Entra admin: exception EX-01).
- Excessive ePHI access (CAN-ID-007) was tested with the synthetic EHR access log in Week 5, not with a running EHR application.
- Host-level incident response was tested separately in Incident Response 1 (IR1-2026-001/002/003).